

통 보

1. 제 목 : 정보시스템 보안 관리에 관한 사항

2. 관계기관 : ●●●●●실

3. 내 용

가. 업무개요

우리 공단에서는 정보시스템 구축 시 정당한 사용 권한을 갖는 사용자에게 하여 정보시스템을 사용할 수 있도록 프로그램을 구성하고, 개인정보 등이 유출되지 않도록 필요한 조치를 취하여 운영하고 있습니다.

나. 로그인 정보 암호화 관련

1) 관계법령 및 판단기준

「개인정보보호법」 제29조(안전조치의무)에 따르면 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 취하여야 합니다.

또한 동법 시행령 제30조(개인정보의 안전성 확보 조치)에 따른 「개인정보의 안전성 확보조치 기준」 제7조(개인정보의 암호화) 제1항에 따르면 개인정보처리자는 비밀번호를 정보통신망을 통하여 송신할 때에는 이를 암호화하여야 한다고 정하고 있습니다.

따라서 요양원 입소자의 개인정보(입소자 성명, 주민번호, 주소, 연락처, 건강정보 등)를 관리하는 요양정보시스템 로그인 시에는 프로그램 사용자가 사용하는 패스워드를 평문으로 입력하고 해당 정보를 정보통신망을 통한 전송 시 패

스위드를 식별하기 어렵도록 암호화하여 전송함으로써 안전성 확보에 필요한 조치를 취해야 합니다.

2) 감사결과 확인된 문제점

그런데 신규로 구축한 요양정보시스템의 패스워드 전송실태를 점검한 결과, 사용자가 입력한 패스워드 정보를 정보통신망을 통하여 전송할 때 암호화하지 않고 평문으로 전송하고 있어 사용자 계정과 패스워드 식별이 가능하였고 그로 인해 개인정보 유출 등의 우려가 있었습니다.

다. 퇴사·전보자의 계정 관리에 관한 사항

1) 관계법령 및 판단기준

공단 「정보보안업무 처리지침」 제24조(사용자계정 관리)에서는 시스템 관리자는 직원의 퇴직 또는 보직 변경 발생 시 사용하지 않는 사용자계정을 신속히 삭제하여야 하고, 정보보안담당관은 사용자계정의 부여 및 관리가 적절한지를 점검하도록 정하고 있습니다.

따라서 요양정보시스템 관리자는 퇴직 또는 보직 변경 발생 시 해당 계정이 더 이상 사용될 수 없도록 신속하게 삭제 조치를 취해야 하고 관리 현황이 적절하게 운영되고 있는지 점검하여야 합니다.

2) 감사결과 확인된 문제점

그런데 요양정보시스템의 사용자 계정 관리 실태를 점검한 결과, [표]와 같이 퇴사하거나 전보하여 더 이상 사용 권한이 없음에도 불구하고 적절한 회수조치가 이행되지 않아 로그인 가능한 상황인 것으로 확인되었습니다.

[표] 요양정보시스템 퇴사·전보자 계정관리 미흡 사례(2022. 9. 5. 기준)

순번	테스트 항목	사번	퇴사·전보일	로그인 성공 화면
1	퇴사자 로그인	189792	2022-08-31	
2	전보자 로그인	101541	2022-07-01	

4. 관계기관 의견

●●●●실에서는 감사결과를 그대로 수용하였으며, 감사결과 처분에 따른 조치를 이행하겠다고 하였습니다.

5. 조치할 사항

○ ●●이사는

- 요양정보시스템의 보안 취약사항은 보완조치하시고, 정당한 사용자만 해당 시스템을 이용할 수 있도록 계정 관리를 철저히 하시기 바랍니다. (통보)